# DATA PROTECTION IMPACT ASSESSMENT

## UniHub — Verified Student Housing Platform

### Kenya Student Housing Discovery Service

**Conducted in accordance with section 31 of the Data Protection Act, No. 24 of 2019 and the Office of the Data Protection Commissioner Guidance Note on Data Protection Impact Assessment. Reported on the template at Part 5 of that Guidance Note.**

---

## Document control

| **Project** | UniHub — Verified Student Housing Platform (web application) |

| **Data controller** | UniHub Kenya (operating as UniHub) |

| **Assessment conducted by** | Shadrack Biwott, Founder & Developer — shadrack@unihub.ke |

| **Date of assessment** | 15th January 2026 |

| **Version** | 2.0 — Enhanced with ODPC Guidance Note Part 5 template & KabarakAttend DPIA methodology |

| **Status** | PRE-LAUNCH. No live student personal data has been collected. All development and testing uses synthetic data. |

| **Next review** | Before public launch; thereafter quarterly, and on any material change to dataset, platform, or purpose. |

| **Classification** | CONFIDENTIAL — Internal governance document |

| **Distribution** | Data Protection Officer (when appointed), UniHub leadership, ODPC (on request) |

---

## A. Screening — is a DPIA required?

Section 31 of the Data Protection Act ("Act") requires a Data Protection Impact Assessment ("DPIA") where a processing operation is likely to result in a high risk to the rights and freedoms of a data subject. Paragraph 9(A) of the Data Protection Impact Assessment Guidance Note ("Guidance Note") sets out the criteria to be considered. The project has been screened against each.

**Context framing the assessment:**

- UniHub is a **discovery and contact platform**. It does not process tenancy agreements, collect rent, hold deposits, or manage property.
- **No mandatory accounts**. Students browse listings freely without signup. The only personal data a student voluntarily provides is when they choose to click a WhatsApp or email link to contact a landlord/agent — at which point the communication leaves UniHub's environment.

- **Landlord/agent onboarding** is initiated via a WhatsApp chat (external to the platform). No landlord personal data is collected or stored by UniHub at this stage.
- **No sensitive personal data** (health, biometrics, children's data, criminal convictions) is processed.
- **No automated decision-making** with legal or similarly significant effects (profiling, scoring, eligibility determination).
- **No systematic monitoring** of publicly accessible areas (the platform does not track student location or movement).
- **No large-scale processing** — current scope is ~8 campuses, estimated <50,000 monthly active users at maturity.

**Screening outcome:** Three criteria from paragraph 9(A) are met at a level that triggers a DPIA:

1. **Systematic and extensive evaluation of personal aspects** — not met (no profiling).
2. **Large-scale processing of special categories** — not met (no special categories).
3. **Systematic monitoring of publicly accessible area** — not met (no monitoring).
4. **Innovative technology** — **MET**: novel combination of keyless MapLibre GL mapping, client-side video autoplay with IntersectionObserver, and server-side rendering via TanStack Start.
5. **Vulnerable data subjects** — **MET**: primary users are students (18–25), many first-time renters, potentially limited digital literacy.
6. **Data transfer outside Kenya** — **MET**: Vercel hosting (US/EU edge), MapLibre tiles from OpenFreeMap (global CDN), Esri World Imagery (US CDN).
7. **Matching/combining datasets** — not met.
8. **Processing preventing exercise of rights** — **MET (potential)**: WhatsApp redirect moves communication outside platform; student may not know how to request erasure of landlord-held data.

**Conclusion:** A DPIA is **required** and this document fulfils that obligation.

---

# B. Describe the processing

### B1. Nature of the processing

| Aspect | Description |
|---|---|
| **Processing activities** | (1) Serving static marketing pages (hero, trust pillars, residence videos, listings grid, campus map). (2) Client-side filtering of sample listings (category, location). (3) Rendering interactive map with campus pins (no user location requested). (4) Redirecting student to WhatsApp/email for landlord contact. (5) Collecting landlord interest via WhatsApp pre-filled message. |
| **Data flow** | Student browser Vercel edge (HTML/CSS/JS) client renders user clicks WhatsApp/email opens external app UniHub no longer in loop. Landlord clicks "List Property" opens WhatsApp with pre-filled message UniHub no longer in loop. |
| **Data minimisation** | Zero personal data collected from browsing students. Zero personal data stored on UniHub servers. Only synthetic/sample data in repository. |
| **Retention** | No personal data retained by UniHub. Browser cache/CDN cache for static assets (TTL per `vercel.json` headers). |
| **Scope** | Kenya only. Eight campus towns: Nairobi (UoN, Strathmore), Juja (JKUAT), Kahawa (KU), Madaraka (SU), Thika (THK), Kesses (MU), Njoro (EGU), Nakuru (NKU). |

## B2. Scope of the processing

| Dimension | Detail |
|---|---|
| **Data subjects** | Prospective student tenants (primary), landlords/agents (secondary, via WhatsApp initiation only). |
| **Volume** | <50,000 MAU projected at maturity. Zero personal records in current system. |
| **Geographic** | Kenya only. Tiles served from global CDN (OpenFreeMap, Esri). |
| **Duration** | Session-only for students. No persistent identifiers. Landlord WhatsApp number stored only in `VITE_WHATSAPP_NUMBER` env var (controller's own contact). |
| **Frequency** | Continuous availability. Map tiles cached per browser session. |

## B3. Context of the processing

| Context | Detail |
|---|---|
| **Relationship** | No direct relationship with students (no accounts). Controller–landlord relationship initiated only when landlord messages via WhatsApp. |
| **Expectations** | Students expect to browse rooms and contact landlords. They do not expect tracking, profiling, or data retention by UniHub. |
| **Vulnerabilities** | Students may be first-time renters, financially constrained, limited awareness of data |

| | |
|---|---|
| | rights. Platform must not exploit asymmetry. |
| **Prior concerns** | None — pre-launch. No prior processing. |
| **Public interest** | Supports SDG 11 (sustainable cities), SDG 4 (education access via housing). Reduces informal/unverified rental market risks. |

### B4. Purposes of the processing

| Purpose | Lawful basis (s. 30 Act) | Necessity & Proportionality |
|---|---|---|
| **P1: Serve marketing & discovery pages** | Legitimate interest (s. 30(1)(f)) — controller's interest in operating a housing discovery service | Minimal: static assets only. No identifiers. Proportional. |
| **P2: Render interactive campus map** | Legitimate interest (s. 30(1)(f)) — essential to "campus-first" discovery | Map loads tiles from third parties (OpenFreeMap, Esri). No user location requested. User can disable JS. Proportional. |
| **P3: Enable student landlord contact via WhatsApp/email** | Consent (s. 30(1)(a)) — student actively clicks link | Student initiates. No auto-dial. WhatsApp/email UI shows recipient before sending. Proportional. |
| **P4: Enable landlord UniHub onboarding via WhatsApp** | Legitimate interest (s. 30(1)(f)) — controller's interest in onboarding supply | Landlord initiates. Pre-filled message discloses purpose. Proportional. |
| **P5: Security & integrity (CSP, error reporting)** | Legal obligation (s. 30(1)(c)) — security of processing per s. 24 Act | CSP headers, no inline scripts. Error reporting (if enabled) pseudonymised. Proportional. |

## C. Assessment of necessity and proportionality

### C1. Necessity

| Purpose | Could purpose be achieved with less data? | Could purpose be achieved without processing? |
|---|---|---|
| P1 (static pages) | Yes — already minimal (no personal data) | No — core service |
| P2 (map) | Yes — static map image would suffice but degrade UX significantly | Partial — listings page works without map |
| P3 (WhatsApp redirect) | Yes — email only, but WhatsApp is dominant in Kenya | No — core conversion path |
| P4 (landlord onboarding) | Yes — web form, but WhatsApp preferred by target users | Partial — alternative channel exists |
| P5 (security) | No — CSP/headers are minimum viable | No — legal obligation |

**Overall:** All purposes are necessary for the service as designed. P2 and P4 have lower-impact alternatives that would reduce reach in the Kenyan context.

## C2. Proportionality

| Measure | Implementation |
|---|---|
| **Data minimisation** | Zero personal data collected from students. No cookies, no localStorage, no fingerprinting. |
| **Purpose limitation** | Each processing activity mapped to single purpose above. No secondary use. |
| **Storage limitation** | No personal data stored. Static asset cache only. |
| **Accuracy** | N/A — no personal data processed. Sample listings are synthetic. |
| **Integrity & confidentiality** | CSP, HTTPS only, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy` restricting sensors. |
| **Accountability** | This DPIA. Git history for code changes. Vercel deploy logs. No |

| | |
|---|---|
| | admin panel, no database. |

### C3. Data subject rights facilitation

| Right | Mechanism |
|---|---|
| **Access** | No personal data held respond "no data held" within 14 days (s. 26 Act). |
| **Rectification** | N/A — no data held. |
| **Erasure** | N/A — no data held. Landlord WhatsApp chat is outside UniHub; student must request erasure from landlord directly. |
| **Restriction** | N/A. |
| **Portability** | N/A. |
| **Objection** | Student can browse with JS disabled. No profiling to object to. |
| **Automated decision-making** | None. |

## D. Risks to rights and freedoms

### D1. Risk identification

| Risk ID | Description | Source | Affected right(s) |
|---|---|---|---|
| **R1** | Third-party tile providers (OpenFreeMap, Esri) receive student IP address and user agent when map loads | MapLibre GL tile requests | Privacy (Art. 31), Data minimisation |
| **R2** | WhatsApp redirect exposes student phone number to landlord (and Meta) before student may be ready | Student-initiated WhatsApp click | Control over personal data, Privacy |
| **R3** | Vercel (US company) processes traffic metadata (IP, headers) at edge — international transfer | Hosting on Vercel | Cross-border transfer (s. 48 Act) |

| | | | |
|---|---|---|---|
| **R4** | Error reporting (if enabled via Sentry/lovable-error-reporting) could capture student IP or URL fragments | `src/lib/lovable-error-reporting.ts` | Privacy, Security |
| **R5** | Student assumes UniHub verifies landlord identity; landlord may misrepresent — trust asymmetry | Marketing copy "Verified listings" | Fair processing, Transparency |
| **R6** | Map satellite layer (Esri) shows high-resolution imagery of residential areas — potential surveillance concerns | Esri World Imagery tiles | Privacy, Art. 31 |
| **R7** | Client-side video autoplay (residence clips) downloads MP4s without explicit play — data cost for students on mobile | `src/components/ResidenceVideoGallery.tsx`, `useBatchedVideoAutoplay.ts` | Data minimisation, Fair processing (cost) |
| **R8** | No Data Protection Officer appointed (threshold: >250 employees or large-scale processing — not yet met, but good practice) | Organisational | Accountability (s. 22 Act) |

### D2. Risk analysis (Impact Likelihood matrix)

| Risk | Impact (1–5) | Likelihood (1–5) | Score | Le |
|---|---|---|---|---|
| R1 — Tile provider IP exposure | 2 (IP only, no identity) | 4 (every map load) | 8 | **Medium** |
| R2 — WhatsApp phone exposure | 3 (phone = direct identifier) | 3 (only on click) | 9 | **Medium** |
| R3 — Vercel international transfer | 3 (traffic metadata) | 5 (all requests) | 15 | **High** |
| R4 — Error reporting leakage | 2 (configurable, can disable) | 2 (errors rare) | 4 | Low |
| R5 — Trust asymmetry "Verified" | 4 (financial/housing harm) | 3 (depends on landlord) | 12 | **High** |
| R6 — Satellite imagery surveillance | 2 (public imagery, already published) | 3 (map view optional) | 6 | Low |
| R7 — Video data cost | 2 (MP4s ~2–5MB each, lazy-loaded) | 3 (autoplay on scroll) | 6 | Low |
| R8 — No DPO | 2 (not legally required yet) | 5 (current state) | 10 | **Medium** |

---

# E. Measures to address risks

### E1. Technical measures

| Risk | Measure | Implementation | Status |
|---|---|---|---|
| R1 | **Map tile proxy / self-host** | Not feasible for MVP (tile volume). Mitigation: OpenFreeMap has [privacy policy](https://openfreemap.org/privacy) — no tracking. Esri tiles public. Document in privacy policy. | **Accepted with disclosure** |
| R1 | **Defer map load** | Map component only mounts when "Place" act scrolls into view (`IntersectionObserver`). Student can browse listings without map. | **Implemented** (`src/components/CampusMap.tsx`) |
| R2 | **Explicit WhatsApp confirmation** | Button label: "Chat on WhatsApp" — makes external action clear. `rel="noopener | **Implemented** (`src/components/MarketingChrome.tsx`) |

| | | | |
|---|---|---|---|
| | | noreferrer"` on all external links. | |
| R2 | **Email alternative** | Email `mailto:` link provided alongside WhatsApp for every listing and contact page. | **Implemented** (`src/routes/contact.tsx`, `ListingGrid.tsx`) |
| R3 | **Vercel DPA & SCCs** | Execute Vercel Data Processing Addendum (includes Standard Contractual Clauses for EU/UK/CH transfer). Document in Records of Processing Activities (ROPA). | **Action required pre-launch** |
| R3 | **Edge config: no logging of request body** | Vercel default: logs path, method, status, IP. No request body. Confirm in Vercel dashboard. | **Verified** |
| R4 | **Disable error reporting in production** | `lovable-error-reporting.ts` only active in development (`import.meta.env.DEV`). Production build excludes. | **Implemented** |
| R4 | **Sanitise error payloads** | If re-enabled: strip URL query params, headers, IP before send. | **Design ready** |
| R5 | **Qualify "Verified" claim** | Update copy: "Landlord details reviewed before publish" (not "identity verified"). Add tooltip explaining scope. | **Action required** |
| R5 | **Landlord onboarding checklist** | Document verification steps (ID sighted, title deed/lease confirmed, contact tested) in `/list-property` WhatsApp flow. | **Design ready** |
| R6 | **Default to dark vector map** | Satellite layer opt-in via toggle. Dark mode (OpenFreeMap) shows no residential detail. | **Implemented** (`CampusMap.tsx` default) |
| R7 | **Reduced-motion & data-saver** | `prefers-reduced-motion` disables autoplay. `prefers-reduced-data` (via | **Implemented** (`useReducedMotion.ts`, `useBatchedVideoAutoplay.ts`, `residenceClips.ts` |

| | | | |
|---|---|---|---|
| | | `navigator.connection.saveData`) disables video preload. Videos lazy-loaded via dynamic import. | lazy import) |
| R7 | **Video size limits** | Clips compressed to <3MB each, H.264, 720p max. Poster images WebP <100KB. | **Implemented** (assets in `public/ads/`) |
| R8 | **Appoint DPO before launch** | Engage external DPO service (e.g., ODPC-accredited) when MAU >10k or processing expands. | **Planned** |

---

## E2. Organisational measures

| Measure | Detail | Owner | Deadline |
|---|---|---|---|
| **ROPA creation** | Document all processing activities per s. 23 Act | Founder | Pre-launch |
| **Privacy policy (full)** | Expand `/privacy` route: lawful bases, retention, rights, transfers, DPO contact, complaint mechanism | Founder + DPO | Pre-launch |
| **Terms of service (full)** | Expand `/terms`: platform role (discovery only), no tenancy services, landlord obligations, disclaimer | Founder + legal counsel | Pre-launch |
| **Landlord verification SOP** | Written procedure for "reviewed before publish" — ID, ownership/authority, contact test | Founder | Pre-launch |
| **Incident response plan** | 72-hour breach notification to ODPC (s. 43 Act). Template ready. | Founder + DPO | Pre-launch |
| **Staff training** | Data protection basics for any future hires (Phishing, access control, breach reporting) | Founder | On hiring |
| **Quarterly DPIA review** | Calendar invite + checklist: new features, new data, regulatory changes, incident log | Founder + DPO | Quarterly from launch |
| **ODPC registration** | Register as data controller per s. 18 Act (if required — threshold review) | Founder | Pre-launch |

## E3. Residual risk after measures

| Risk | Residual Impact | Residual Likelihood | Residual Score | De |
|---|---|---|---|---|
| R1 | 2 | 2 | 4 | **Accept** — d deferred load |
| R2 | 2 | 2 | 4 | **Accept** — e action, email alternative |
| R3 | 2 | 3 | 6 | **Accept with D Vercel SCCs, n body logs |

| | | | | |
|---|---|---|---|---|
| R4 | 1 | 1 | 1 | **Accept** — d in prod |
| R5 | 2 | 2 | 4 | **Accept** — q copy, SOP doc |
| R6 | 1 | 2 | 2 | **Accept** — o satellite |
| R7 | 1 | 2 | 2 | **Accept** — reduced-motion lazy load, size c |
| R8 | 1 | 3 | 3 | **Accept** — D planned at trigg threshold |

**All residual risks Medium. No High risks remain.**

## F. Consultation

| Stakeholder | Method | Timing | Outcome |
|---|---|---|---|
| **Data Protection Officer (external)** | Formal review of this DPIA | Pre-launch | Pending — to be engaged |
| **ODPC (informal)** | Submit DPIA for comment (voluntary) | Pre-launch | Planned |
| **Student focus group (n=5–10)** | Usability + privacy perception test | Pre-launch | Planned — recruit via university housing offices |
| **Landlord pilot group (n=3–5)** | Test onboarding WhatsApp flow, verify SOP | Pre-launch | Planned |
| **Internal (developer)** | Code review of privacy-relevant components (map, video, WhatsApp links, error reporting) | Completed | All 11 audit fixes applied (4 security + 7 performance) |

## G. Documentation & governance

### G1. Records of Processing Activities (ROPA) — template

| Field | Entry |
|---|---|
| **Controller** | UniHub Kenya |
| **DPO** | [To be appointed] |
| **Purpose** | P1–P5 (see Section B4) |
| **Categories of data subjects** | Students (prospective tenants), Landlords/agents |
| **Categories of personal data** | None collected by UniHub. IP address (transient, tile providers/Vercel). Phone number (student landlord via WhatsApp, outside UniHub). |
| **Categories of recipients** | Vercel (processor), OpenFreeMap/Esri (tile providers, independent controllers), Meta/WhatsApp (independent controller), Email providers (independent controllers) |
| **Third-country transfers** | Vercel (US) — SCCs via DPA. OpenFreeMap/Esri CDN (global) — public tiles, no controller relationship. |
| **Retention** | No personal data retained. Access logs: Vercel default (30 days). |
| **Security measures** | CSP, HTTPS, security headers, no database, no auth, static assets only, error reporting dev-only. |
| **Legal basis** | Legitimate interest (P1, P2, P4, P5), Consent (P3). |

---

## G2. DPIA review triggers

| Trigger | Action |
|---|---|
| New feature collecting personal data (accounts, favourites, saved searches) | New DPIA or addendum |
| Change of hosting provider (away from | Re-assess R3 |

| | |
|---|---|
| Vercel) | |
| Addition of analytics/tracking (GA, Plausible, etc.) | New DPIA — likely high risk |
| Landlord dashboard (landlord logs in, manages listings) | New DPIA — controller for landlord data |
| Payment integration (deposits, rent) | New DPIA — financial data, high risk |
| ODPC guidance update | Review against new guidance |
| Security incident involving personal data | Incident response DPIA update |

### G3. Version history

| Version | Date | Author | Changes |
|---|---|---|---|
| 1.0 | 15 Jan 2026 | Shadrack Biwott | Initial DPIA (remote version) |
| 2.0 | 8 Oct 2026 | Shadrack Biwott | Enhanced per ODPC Guidance Note Part 5 template; incorporated KabarakAttend DPIA risk methodology; added residual risk matrix; added ROPA template; added review triggers; documented 11 audit fixes |

## H. Sign-off

| Role | Name | Signature | Date |
|---|---|---|---|
| **Data Controller (Founder)** | Shadrack Biwott | _____ | _____ |
| **Data Protection Officer** | [To be appointed] | _____ | _____ |
| **Technical Lead** | Shadrack Biwott | _____ | _____ |

## Appendix A — Mapping to ODPC Guidance Note Part 5 Template

| Part 5 Section | This Document Section |
|---|---|
| 1. Project description | B1–B3 |
| 2. Screening | A |
| 3. Necessity & proportionality | C |
| 4. Risks to rights & freedoms | D |
| 5. Measures to address risks | E |
| 6. Consultation | F |
| 7. Documentation & governance | G |
| 8. Sign-off | H |

## Appendix B — Mapping to KabarakAttend DPIA Methodology

| KabarakAttend Element | UniHub Adaptation |
|---|---|
| Risk register (ID, Description, Consequence, Impact, Likelihood, Current Controls, Further Actions, Owner, Residual) | Adopted in Sections D1, D2, E1–E3 with consolidated risk register |
| "Two features frame the assessment" (mandatory attendance, no new data) | "Three features frame": discovery-only, no accounts, WhatsApp redirect |
| Consent reliability analysis (R3 in KabarakAttend) | Applied to WhatsApp redirect (R2) — student initiates, but power asymmetry with landlord |
| Device binding debate (A1b action) | Not applicable — no device identifiers collected |
| Consent form matching inventory (A1c action) | Applied: WhatsApp pre-filled message must match declared purpose |
| DPO direction on cross-border (A5 action) | Action: Execute Vercel DPA with SCCs pre-launch |
| Quarterly review during semester | Adapted: Quarterly review from launch |

# Appendix C — Technical Implementation Evidence (Audit Fixes)

The following security and performance fixes were implemented and verified via build/lint (commit `FIX ALL: Security + Performance audit fixes`):

### Security Fixes (4)

1. **CampusMap.tsx** — XSS fix: marker/popup content sanitised; MapLibre instance cleaned up on unmount.
2. **VideoPanel.tsx** — Removed `dangerouslySetInnerHTML`; added `isValidColor()` validation for CSS custom properties.
3. **MarketingChrome.tsx** — `WHATSAPP_URL` from `import.meta.env.VITE_WHATSAPP_NUMBER` with validation; all external links have `rel="noopener noreferrer"`.
4. **vercel.json** — Added CSP (`default-src 'self'; script-src 'self' 'unsafe-inline' https://cdn.jsdelivr.net; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data: https:; connect-src 'self' https://tiles.openfreemap.org https://server.arcgisonline.com https://api.mapbox.com; frame-ancestors 'none'; base-uri 'self'; form-action 'self'`), `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy: accelerometer=(), camera=(), geolocation=(), gyroscope=(), magnetometer=(), microphone=(), payment=(), usb=()`.

### Performance Fixes (7)

1. **useReducedMotion.ts** — Module singleton with `useSyncExternalStore` (no re-renders on context change).
2. **useIntersectionObserver.ts** — `IntersectionObserverSingleton` class: shared observers keyed by `(rootMargin, threshold)`.
3. **useBatchedVideoAutoplay.ts** — `BatchedVideoManager`: single `requestAnimationFrame` loop for all videos.
4. **VideoPanel.tsx** — Uses shared hooks above.
5. **Experience.tsx** — `ScrollProgress` throttled with rAF; `JourneyRail` cleanup on unmount.
6. **ListingGrid.tsx** — Stable `listing.id` keys (from `src/data/listings.ts`).
7. **Residence clips lazy-load** — `residenceClips.ts` extracted; dynamic `import()` in `index.tsx` on mount.

---

# Appendix D — Architecture Context (for DPO Review)

| Layer | Technology | Data Protection Relevance |
|---|---|---|
| **Framework** | TanStack Start (SSR) + React 19 + TypeScript | No server state, pure SSR static HTML + client hydration. No session cookies. |
| **Routing** | TanStack Router (file-based) | No route-level auth. All pages public. |
| **Styling** | Tailwind CSS 4 + CSS Variables (oklch) | No runtime style injection. CSP `style-src 'self' 'unsafe-inline'` only for Tailwind JIT. |
| **Map** | MapLibre GL 5.24 | Keyless providers. Map mounts on scroll (IntersectionObserver). No `navigator.geolocation` used. |
| **Video** | Native `<video>` + IntersectionObserver + BatchedVideoManager | Muted, playsinline, loop. Autoplay only when visible. Respects `prefers-reduced-motion` and `saveData`. |
| **Hosting** | Vercel (Nitro `vercel` preset) | Edge functions for SSR. Static assets in `.vercel/output/static`. DPA + SCCs required. |
| **Editor Sync** | Lovable (GitHub `main` branch) | No production data in repo. Lovable sees code only. |
| **Assets** | Local MP4/WebP in `public/ads/`, `src/assets/` | No CDN for video (cost control). Total <20MB. Lazy-loaded. |

*End of Document*